25 Authentication and authorization for APIs

This chapter covers

- Seeing how authentication works for APIs in ASP.NET Core
- Using bearer tokens for authentication
- Testing APIs locally with JSON Web Tokens
- Applying authorization policies to minimal APIs

In chapter 23 you learned how authentication works with traditional web apps, such as those you would build with Razor Pages or Model-View-Controller (MVC) controllers. Traditional web apps typically use encrypted cookies to store the identity of a user for a request, which the `AuthenticationMiddleware` then decodes. In this chapter you'll learn how authentication works for API applications, how it differs from traditional web apps, and what options are available.

We start by taking a high-level look at how authentication works for APIs, both in isolation and when they're part of a larger application or distributed system. You'll learn about some of the protocols involved, such as OAuth 2.0 and OpenID Connect; patterns you can use to protect your APIs; and the tokens used to control access, typically JSON Web Tokens, called JWTs.

In section 25.3 you'll learn how to put this knowledge into practice, adding authentication to a minimal API application using JWTs. In section 25.4 you'll learn how to use the .NET command-line interface (CLI) to generate JWTs for testing your API locally.